



Powered by **Arizona State University®**

Alumno: Luis Alberto Vargas González.

Fecha: 27/05/2026.

**Tarea : Unidad 2 A2: Sistema de gestión de seguridad usando
ISO 27001 y COBIT.**

Maestría en Ciberseguridad.

INDICE.

1. Portada.

2. Introducción.

3. Fundamentos de ISO 27001/COBIT .

4. Entorno Empresarial.

5. Diseño del plan de Seguridad con ISO 27001/COBIT.

6. Establecimiento de controles .

7. Implementación y monitoreo.

8. Evaluación y mejora continua.

9. Conclusión.

2. Introducción

En el escenario contemporáneo de la educación superior virtual, la información se ha consolidado como el activo más crítico y, simultáneamente, el más expuesto dentro de las organizaciones. Para la Universidad Digital de las Américas (UDA), una institución nativa digital con una comunidad de más de 5,000 estudiantes y operaciones 100% en la nube, un fallo en la seguridad no solo representa una interrupción técnica, sino una amenaza directa a la continuidad académica y a la confianza institucional. Proteger un entorno tan dinámico exige una estructura de gobernanza que trascienda las soluciones técnicas aisladas.

Este informe presenta el Plan de Implementación de un Sistema de Gestión de Seguridad de la Información (SGSI) para la UDA, diseñado bajo un enfoque híbrido que integra los requisitos de la norma internacional ISO/IEC 27001:2022 y los principios de gobernanza del marco COBIT. Mientras que la norma ISO proporciona el diseño de los controles técnicos y organizativos necesarios para mitigar los riesgos, COBIT asegura que la seguridad de la información esté alineada con los objetivos estratégicos y financieros de la alta dirección. A través de esta evaluación y propuesta de consultoría, se establece una hoja de ruta detallada para la implementación, monitoreo y mejora continua del SGSI, garantizando la resiliencia operativa de la universidad ante el panorama actual de amenazas cibernéticas.

3. Fundamentos de ISO/IEC 27001 y COBIT

a) Fundamentos de los Marcos de Referencia

- **ISO/IEC 27001:2022:** Es el estándar internacional certificable que define los requisitos para establecer, implementar, mantener y mejorar continuamente un Sistema de Gestión de Seguridad de la Información (SGSI). Su enfoque se basa en la gestión de riesgos para preservar la confidencialidad, integridad y disponibilidad de la información a través de una estructura de alto nivel y un conjunto de controles agrupados en cuatro dominios (Organizacionales, Personas, Físicos y Tecnológicos).
- **COBIT (Control Objectives for Information and Related Technologies):** Es un marco global para la Gobernanza y Gestión de las Tecnologías de la Información empresarial. COBIT no es una norma de seguridad per se; es un modelo que divide las funciones de TI en dos grandes áreas: *Gobierno* (Evaluar, Dirigir y Monitorear) y *Gestión* (Planificar, Construir, Ejecutar y Monitorear), asegurando que la tecnología genere valor al negocio, optimice los recursos y mitigue los riesgos corporativos.

b) Integración y Complementariedad de ambos Marcos

La unión de ISO 27001 y COBIT genera una sinergia perfecta para el Blue Team y la gobernanza de GRC debido a que resuelven diferentes capas del problema:

- **COBIT aporta el "Para qué" (La Estrategia):** Ayuda a la universidad a definir las métricas de alineación. Por ejemplo, establece el objetivo de que la seguridad de la información debe apoyar a la retención de alumnos y la estabilidad de los ingresos por colegiaturas.
- **ISO 27001 aporta el "Cómo" (La Ejecución):** Traduce las metas de COBIT en un sistema operativo real. Si COBIT pide "mitigar el riesgo de pérdida de datos académicos", ISO 27001 despliega el control específico A.8.12 (Gestión de datos) y A.8.24 (Uso de criptografía).

En la práctica, se integran utilizando los objetivos de control de COBIT (específicamente el dominio *APO13: Gestionar la Seguridad* y *MEA02: Evaluar el Sistema de Control Interno*) como el mecanismo de supervisión que audita y reporta a la junta directiva el desempeño del SGSI de ISO 27001. Esto evita que la ciberseguridad se vea como un gasto técnico aislado y la convierte en un habilitador estratégico del negocio educativo.

4. Entorno Empresarial.

Para mantener la coherencia metodológica del proyecto de consultoría, se mantiene como caso de estudio a la **Universidad Digital de las Américas (UDA)**.

a) Contexto Institucional y Necesidades Específicas

- **Estructura Organizativa:** La UDA cuenta con una junta directiva encabezada por el Rector. Las decisiones tecnológicas dependen de la Dirección de TI, la cual cuenta con una Jefatura de Soporte Técnico. Como parte de las brechas identificadas previamente, se requiere la creación formal de la función del **CISO (Chief Information Security Officer)** para separar la operación técnica de la gobernanza de la seguridad.
- **Necesidades de Seguridad:** Al ser una institución 100% virtual, sus principales necesidades son garantizar la disponibilidad continua de su plataforma de aprendizaje (LMS Canvas) y proteger la integridad de los datos académicos frente a accesos no autorizados. El negocio educativo de la UDA depende críticamente de que no ocurran interrupciones que superen las 4 horas (RTO).

b) Activos Críticos y Riesgos Asociados (Enfoque ISO 27001).

Bajo los dominios de la norma ISO/IEC 27001, los activos se evalúan en función de su impacto a la confidencialidad, integridad y disponibilidad (CID):

- 1º **Información de Identidad y Credenciales (SSO):** Riesgo elevado de compromiso de cuentas administrativas (*Account Takeover*) por la ausencia de requerimientos de complejidad en contraseñas. Afecta la Confidencialidad y Disponibilidad.
- 2º **Base de Datos Académica (Calificaciones y Entregas):** Riesgo de alteración no autorizada de datos mediante inyección de código (SQLi) o pérdida total por secuestro de información (*Ransomware*). Afecta la Integridad y Disponibilidad.

5. Diseño del Plan de Seguridad

a) Objetivos y Alcance del SGSI

- **Alcance:** El SGSI abarcará exclusivamente al **Ecosistema de Autenticación Única (SSO) y la Plataforma de Gestión de Aprendizaje (LMS Canvas)**, incluyendo los flujos de datos de estudiantes, docentes y administradores de la UDA.
- **Objetivos del SGSI (Alineados con COBIT):**
 - Garantizar una disponibilidad del 99.9% en los servicios del LMS durante los periodos de evaluación crítica (Meta de Negocio - COBIT).
 - Reducir a cero el número de incidentes de seguridad causados por contraseñas débiles o falta de MFA en un plazo de 90 días (Meta de TI - ISO 27001).

b) Roles y Responsabilidades

Para asegurar el mantenimiento del sistema, se define la siguiente matriz de responsabilidades básica:

- **Comité de Seguridad (Alta Dirección):** Evalúa y aprueba el presupuesto, las políticas institucionales y revisa el desempeño global (Rol de Gobierno en COBIT).
- **CISO (Oficial de Seguridad):** Responsable de diseñar, implementar y coordinar el SGSI, así como de reportar las métricas de cumplimiento a la dirección.
- **Equipo de TI y Soporte:** Ejecutan los controles técnicos diarios (parches, monitoreo, respaldos) y operan como la primera línea de defensa táctica (Blue Team).

c) Cronograma y Fases de Implementación (Ciclo PDCA)

La implementación se proyecta a un plazo de **6 meses**, dividida en cuatro etapas principales:

1º Fase 1: Planificar (Mes 1 - 2): Desarrollo del análisis de brechas final, inventario detallado de activos y redacción del cuerpo de políticas base (Control de accesos, respaldos). *Recursos:* Consultor externo y CISO.

2º Fase 2: Hacer (Mes 3 - 4): Despliegue técnico de los controles. Configuración obligatoria de la Autenticación Multifactor (MFA), enrolamiento de usuarios, instalación del WAF perimetral para proteger las APIs y automatización de respaldos inmutables en la nube. *Recursos:* Administradores de infraestructura de TI.

3º Fase 3: Verificar (Mes 5): Ejecución de las primeras auditorías internas e inicio de las campañas de concientización y simulación de *phishing* al personal. Monitoreo de la efectividad de los controles instalados. *Recursos:* Auditor interno y herramientas de simulación.

4º Fase 4: Actuar (Mes 6): Revisión de hallazgos por parte de la alta dirección, aplicación de acciones correctivas sobre los controles que muestren desviaciones y formalización del proceso de mejora continua.

Interacción entre áreas: El proceso de implementación requiere una comunicación constante entre la Dirección de TI y la Coordinación Académica. El despliegue del MFA, por ejemplo, no puede hacerse de manera aislada; debe coordinarse con el área académica para capacitar a los docentes y evitar que el cambio de control bloquee el acceso a las aulas virtuales durante las semanas de exámenes.

6. Establecimiento de controles de seguridad.

Para mitigar de forma estructurada los riesgos críticos identificados en el ecosistema tecnológico de la UDA, se realiza una correlación directa entre los riesgos evaluados bajo la metodología MAGERIT (en la fase previa) y los controles específicos contenidos en el **Anexo A de la norma ISO/IEC 27001:2022**.

a) Mapeo de Riesgos y Selección de Controles (ISO 27001 / MAGERIT)

A continuación, se documentan los controles requeridos, clasificados según su naturaleza operativa, garantizando un enfoque de defensa en profundidad:

- **Controles Técnicos (Tecnológicos):**
 - **Control A.8.5 (Autenticación segura):** Implementación obligatoria de un sistema de Autenticación Multifactor (MFA) integrado al SSO de la universidad. Este control técnico mitiga directamente el riesgo **R-05** (Secuestro de cuentas administrativas y docentes).
 - **Control A.8.20 (Seguridad en redes) y A.8.15 (Filtrado de tráfico):** Despliegue de un Web Application Firewall (WAF) y el servicio perimetral AWS Shield Advanced. Estos controles actúan contra el riesgo **R-01** (Ataques DDoS masivos) y el riesgo **R-03** (Inyecciones SQL en formularios web), bloqueando peticiones maliciosas antes de que impacten la infraestructura de Canvas.
- **Controles Organizacionales:**
 - **Control A.5.15 (Control de acceso) y A.5.16 (Gestión de identidades):** Redacción y oficialización de la Política de Control de Accesos de la UDA, la cual dictará las reglas de complejidad, longitud mínima de caracteres y el ciclo obligatorio de rotación de contraseñas cada 90 días.
 - **Control A.8.13 (Copias de seguridad):** Automatización de respaldos inmutables en la nube mediante AWS Backup. Las copias de seguridad de las calificaciones y expedientes se almacenarán con políticas de retención estrictas y aislamiento lógico de la red corporativa, neutralizando el impacto del riesgo **R-02** (Ataque de Ransomware).

- **Controles de Gestión:**
- **Control A.5.3 (Segregación de funciones):** Reestructuración del organigrama de TI de la universidad. Se establece una división clara de responsabilidades donde el personal que ejecuta las tareas operativas cotidianas (Mesa de Soporte Técnico) no posee permisos para autorizar cambios en las políticas de seguridad ni auditar los registros de acceso (*logs*), funciones que ahora son exclusivas del área del CISO.

7. Implementación y monitoreo del SGSI.

a) Estrategia de Despliegue de los Controles

La aplicación de los controles definidos se realizará de manera escalonada para no interrumpir el flujo académico de la plataforma Canvas:

1º Fase Piloto: Se activará el MFA y las nuevas políticas de contraseñas únicamente en el departamento de TI y las cuentas directivas de la UDA durante las primeras dos semanas.

2º Fase General: Una vez estabilizado el proceso piloto, se extenderá el control de acceso a la plantilla docente y, finalmente, al total de la comunidad estudiantil de forma obligatoria para el inicio del siguiente ciclo escolar.

b) Sistema de Seguimiento y Monitoreo (Alineación con COBIT)

Para evaluar continuamente la efectividad del SGSI y reportar resultados objetivos a la alta dirección, se establece un tablero de control basado en Indicadores Clave de Rendimiento (KPIs) e Indicadores Clave de Riesgo (KRIs), alineados con el dominio de supervisión **MEA de COBIT**:

- **Métrica de Cobertura IAM:** Porcentaje de usuarios activos con MFA habilitado (Meta: 100% en roles administrativos/docentes, >95% en alumnos).
- **Métrica de Resiliencia (Efectividad del DRP):** Tiempo real de restauración de la Base de Datos en simulacros programados (Meta: Menor a 4 horas para cumplir con el RTO establecido).
- **Métrica de Seguridad Perimetral:** Número de intentos de inyección SQL detectados y bloqueados por el WAF de manera mensual.
- **Métrica de Cultura (Security Awareness):** Tasa de clics fallidos en las campañas trimestrales de simulación de *phishing* controlado (Meta: Reducir la tasa de vulnerabilidad humana por debajo del 5%).

c) Documentación y Capacitación del Personal

Toda la operación del SGSI se respaldará mediante manuales de procedimientos operativos estandarizados (SOP). El equipo de soporte técnico recibirá capacitación especializada para la gestión de alertas del WAF y el procedimiento de restablecimiento de tokens MFA. Asimismo, se creará un portal de autoservicio con guías visuales sencillas para que los alumnos configuren correctamente sus aplicaciones de autenticación, asegurando la adhesión de toda la comunidad sin saturar las líneas de atención técnica.

8. Evaluación y mejora continua.

La sostenibilidad a largo plazo del SGSI en la Universidad Digital de las Américas (UDA) depende de su capacidad para adaptarse a los cambios tecnológicos y a las nuevas variantes de amenazas. Para ello, se adopta el enfoque de mejora continua basado en el ciclo PHVA (Planear, Hacer, Verificar, Actuar) exigido por la norma ISO/IEC 27001.

a) Auditorías Internas Periódicas

Se establece un programa de auditoría interna con una frecuencia semestral. Estas revisiones serán ejecutadas por un auditor certificado independiente del equipo operativo de TI (garantizando la segregación de funciones) o por una firma de consultoría externa. El objetivo de la auditoría será verificar que los controles del Anexo A (MFA, WAF, respaldos inmutables) sigan operando conforme a los requisitos de la norma y detectar posibles desviaciones antes de que sean explotadas por un agente de amenaza.

b) Revisión por la Dirección y Acciones Correctivas

Los resultados de las auditorías internas, el comportamiento de las métricas de monitoreo (KPIs/KRIs de COBIT) y las bitácoras de incidentes serán consolidados por el CISO en un informe de desempeño. Este informe se presentará formalmente ante el Comité de Seguridad y la Alta Dirección en sesiones de revisión anuales.

Cuando se detecte una falla en un control (por ejemplo, un aumento en la tasa de clics en correos de *phishing* simulados), se activará un procedimiento de **Acción Correctiva**. Este proceso implica:

1º Analizar la causa raíz del problema.

2º Diseñar e implementar un plan de mitigación con un responsable y un plazo definido.

3º Evaluar la efectividad de la corrección en un periodo posterior de 30 días para asegurar que el riesgo ha regresado a niveles aceptables.

c) Fomento de una Cultura de Seguridad

La mejora continua no se limita a parches técnicos. La UDA integrará la ciberseguridad dentro de los procesos de inducción formal para todo el nuevo personal administrativo y docente. Asimismo, se institucionalizará un canal confidencial de reporte de anomalías digitales, incentivando a la comunidad universitaria a notificar activamente comportamientos sospechosos o posibles incidentes de ingeniería social, convirtiendo el factor humano en un componente activo del Blue Team institucional.

9. Conclusión.

La ejecución de este plan de consultoría estratégica demuestra que la seguridad de la información en una institución de educación superior virtual no puede gestionarse de forma aislada mediante esfuerzos puramente técnicos. El diseño e implementación de un SGSI robusto requiere un matrimonio estructural entre la gobernanza corporativa y el control operativo.

La integración de la norma **ISO/IEC 27001** y el marco **COBIT** dota a la Universidad Digital de las Américas (UDA) de una arquitectura de defensa en profundidad y un modelo de gobierno de TI sin precedentes en su operación. Mientras que los controles técnicos específicos implementados (como el WAF perimetral, las copias de seguridad inmutables y la Autenticación Multifactor) cierran de inmediato las brechas críticas y protegen la integridad de las calificaciones y la disponibilidad del LMS Canvas, el marco COBIT asegura que estas inversiones tecnológicas se traduzcan en valor directo para el negocio, garantizando la retención estudiantil, la protección reputacional y el cumplimiento de los tiempos de recuperación (RTO).

Al transitar de un estado de seguridad reactivo e informal a un sistema de gestión estandarizado, documentado y auditado, la UDA no solo mitiga el impacto financiero de amenazas críticas como el *Ransomware* o el secuestro de identidades, sino que consolida su posición en el sector EdTech como una institución resiliente, confiable y plenamente preparada para garantizar la continuidad académica de su comunidad en el entorno digital.